

Toets: Software Developer Security

Datum: 30 maart 2026

De situatie Je werkt bij het bedrijf SumSang Software Development. Een stagiair heeft een inlogpagina gemaakt met HTML en PHP. Na controle blijkt dat deze pagina nog onveilig is. Jij gaat de code beveiligen voordat deze online op Git mag.

Je mag geen AI gebruiken en ook niet samenwerken met andere. Je mag wel je eerder gemaakt werkt van jezelf gebruiken voor de opdracht

Stap 1: Voorbereiding

- Ga naar de website: **pieterleek.nl/toets** en download het startproject.
- Het wachtwoord om te downloaden is: **security2026**
- Pak het ZIP-bestand uit.
- Zet de bestanden in de map htdocs van je XAMPP.
- Open de pagina in je browser via localhost.
- De database kan je bereiken via www.pieterleek.nl/phpmyadmin Gegevens voor de database staan in het login.php script.

Belangrijke regels vooraf

- De HTML en CSS zijn al klaar. Deze mag je **niet** veranderen.
- Je werkt **alleen** in het bestand login.php.

De Opdrachten

Opdracht 1: Verberg de databasegegevens (.env) Nu staan de inloggegevens van de database gewoon los (hardcoded) in login.php. Dat is onveilig, want iedereen op Git kan dit lezen.

- Maak een nieuw bestand aan in je project en noem dit **.env** (een environment bestand).
- Verplaats de inloggegevens van de database naar dit nieuwe .env bestand.
- Pas je PHP-code zo aan dat het script de inloggegevens uit het .env bestand ophaalt.

Opdracht 2: Voorkom hackers (Prepared Statements) De code die praat met de database (de query) is nu onveilig. Hackers kunnen inbreken via een zogenaamde 'SQL injection'.

- Pas de database query in login.php aan.
- Zorg ervoor dat je hiervoor **prepared statements** gebruikt.

Opdracht 3: Wachtwoorden beveiligen (Hashing) Op dit moment staan de wachtwoorden van gebruikers als gewone, leesbare tekst in de database. Bij een hack kunnen deze direct gestolen worden.

- Zorg ervoor dat de wachtwoorden versleuteld (**gehasht**) in de database worden opgeslagen.
- Pas je script zo aan dat de inlogfunctie ook netjes blijft werken met deze gehashte wachtwoorden.

Stap 2: Inleveren

Ben je helemaal klaar met de opdrachten en werkt je code veilig?

- Lever je aangepaste script en eventueel andere bestanden waarin je hebt gewerkt in via: www.pieterleek.nl/inleveren